Assignment Report

Computing and Information Sciences
Semester I, Academic Year 2025 - 2026
CSSY3202 - Web Applications Security

TITLE : **Web Server Security Assessment Using Nikto: A Comprehensive Methodology**

NAME : _____

ID : _____

Supervisor : **Ramesh Palanisamy**

TABLE OF CONTENTS

1. Abstract
2. Introduction
3. Methodology
4. Result and discussion
5. Conclusion
6. Reference

Web Server Security Assessment Using Nikto: A Comprehensive Methodology

1. Abstract

This article provides a simple, organized way to use the Nikto scanner to check web server security. It combines information from a ten-part series into one guide that covers advanced scanning techniques, how Nikto is designed, how to use it in practice, key security ideas, and how to fit it into current security practices. The article shows that Nikto is a useful, open-source tool for finding a variety of known web server problems, like outdated software, insecure files, and information leaks. It helps security experts, system administrators, and developers improve their organization's security by offering step-by-step instructions from installation and setup to analyzing results and automating tasks. The article also discusses the limits of the tool in a broader context, emphasizing that while Nikto is helpful, it should be part of a larger security plan rather than the only solution.

2. Introduction

The web server is a vital, public-facing entry point to an organization's digital resources and services. Vulnerabilities within web server ecosystems, including server software, operating systems, and configurations are attractive targets in today's threat landscape. These vulnerabilities can lead to serious consequences, such as financial loss, reputational damage, and operational disruptions. To mitigate these risks, a proactive protection approach is necessary, especially considering common vulnerabilities like application weaknesses, outdated software, and misconfigurations. Automated vulnerability scanners play a crucial role in this proactive strategy. One notable tool is Nikto, a specialized open-source web server and web application analyzer. Unlike broad-spectrum network scanners such as Nessus or OpenVAS, or manual application testing tools like Burp Suite or OWASP ZAP, Nikto focuses specifically on the server infrastructure layer. It effectively identifies known risks by leveraging a comprehensive database that includes over 6,700 potentially hazardous files and more than 1,250 outdated server versions.The aim of this study is to present a thorough approach to effectively utilizing Nikto. It will guide the reader from fundamental concepts to advanced implementation, ensuring that the tool is integrated into a comprehensive security assessment process rather than used in isolation.

3. Methodology

To establish a reliable technique for evaluating web servers using Nikto, a methodical approach was adopted. The process consists of four main stages: Preparation, Execution, Analysis, and Integration.

3.1. Setting Up and Installing

There are steps to set up and install Nikto:

Step 1: System Requirements

- Operating System: Nikto is compatible with Unix-based systems (like Linux and macOS) as well as Windows.
- Perl: Ensure that Perl is installed on your machine since Nikto is built using Perl.

Step 2: Installing Dependencies

Before you can install Nikto, you may need to install various Perl modules. These can usually be added using your system's package manager.

For Debian/Ubuntu: `sudo apt-get install git libwww-perl libnet-ssleay-perl libcrypt-ssleay-perl`

For CentOS/RHEL: `sudo yum install git perl-HTTP-Daemon perl-IO-Socket-SSL`

Step 3: Downloading Nikto

Clone the Repository:

Use Git to clone the Nikto repository: (git clone https://github.com/sullo/nikto.git)

Change to the Nikto Directory: (`cd nikto`)

Step 4: Running Nikto

1. Make the Script Executable:
    - Ensure that the Nikto scripts have executable permissions: (`chmod +x nikto.pl`)
2. Run Nikto:

- You can now run Nikto using the following command: (`perl nikto.pl -h NameOfWebsite`), However, you can Replace 'NameOfWebsite' with the URL or IP address of the server you wish to scan.

Step 5: Configuring Nikto

- Configuration File: You can customize various settings in the `nikto.conf` file found in the Nikto directory. Adjust paths, plugins, and other configurations according to your needs.

```
┌──(kali㉿kali)-[~/nikto/program]
└─$ apt-get install nikto
Reading package lists ... Done
Building dependency tree ... Done
Reading state information ... Done
nikto is already the newest version (1:2.5.0+git20230114.90ff645-0kali1).
0 upgraded, 0 newly installed, 0 to remove and 583 not upgraded.
```

3.2. Execution of Scanning

A layered scanning process was employed to achieve a balance between efficiency and depth.

- **Basic Scan:** The command (`nikto -h nameOfwebsite`) is used for initial reconnaissance. There is example for https://www.google.com :

```
┌──(kali㉿kali)-[~/nikto/program]
└─$ nikto -h https://www.google.com
Nikto v2.5.0
---------------------------------------------------------------------------
Multiple IPs found: 142.251.39.4, 2a00:1450:400d: 80c: :2004
Target IP: 142.251.39.4
Target Hostname: www.google.com
Target Port: 443
---------------------------------------------------------------------------
SSL Info: Subject: /CN=www.google.com
Altnames: www.google.com
Ciphers: TLS AES 256 GCM SHA384
Issuer: /C=US/0=Google Trust Services/CN=WR2
Start Time: 2025-11-6 02:18:43 (GMT2)
---------------------------------------------------------------------------
Server: gws
/:X-Frame-Options header is deprecated and has been replaced with the Content-Security-Policy HTTP header with the frame-ancestors directiveinstead. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
/: Uncommon header(s) 'accept-c h' found, with contents: Sec-CH-Prefers-Color-Scheme
/: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Heders/Strict-Transport-Security
/: An alt-svc header was found which is advertising HTTP/3. The endpoint is: ':443'. Nikto cannot test HTTP/3 over QUIC. See: https://develoer.mozilla.org/en-US/docs/Web/HTTP/Headers/alt-svc
/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion tothe MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
```

- **Comprehensive Scan:** This scan includes multiple ports, precise tuning, and formatted output. The command used is: (`nikto -h https://www.google.com -p 80,443,8080 -o report.html -F htm -T 489`)

  Breakdown of the Command:

  1. `-h https://www.google.com:` Specifies the target host.
  2. `-p 80,443,8080:` Scans the specified ports (HTTP and HTTPS).
  3. `-o report.html:` Outputs the scan results to a file named report.html.
  4. `-F htm:` Sets the output format to HTML.
  5. `-T 489:` Adjusts the timeout settings for the scan.

- **Advanced Scan:** This approach employs plugins to enhance functionality and utilize evasion strategies

```
┌──(kali㉿kali)-[~/nikto/program]
└─$ nikto -h https://www.google.com -p 80,443,8080 -o report.html -F htm -T 489
Nikto v2.5.0
---------------------------------------------------------------------------
Multiple IPs found: 142.251.39.4, 2a00:1450:400d: 80c: :2004
Target IP: 142.251.39.4
Target Hostname: www.google.com
Target Port: 443
Start Time: 2025-11-6 02:18:43 (GMT2)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
+ Uncommon header 'x-seen-by' found, with contents: jeslxIFvDH4ulYwNNi+3Muwfbs+7qUVAqsIx00yI78k=,BTzakfJUbU/4CBguyutVd1BmDjYppDd6MXvikk+MVGE=,1wy2ILu/S4rlWT/R4rqCraLRI8OwLNGWc7hr3zKQKbQ=,qQbTLsvPZVUXp9HeAm/lzCzmjHSAtN8hPDNDrwifBBFGp/J3MBzgzU8QHrQuh4zQ,8P0mj0DyBDQfR+g1fwr/xp3Q4gP1j6qD9Tfws507uD7NlzNbIE9+kMNtoOI312MB2vT8YZDbATa6fuoniUX5lg==
+ Uncommon header 'x-wix-request-id' found, with contents: 1579679313.75115545931141315634
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type
+ Root page / redirects to: https://w.thestudentscircle.com/
```

  to bypass basic protections. Nikto allows the use of specific plugins like (`nikto -h https://www.google.com -Plugins "apacheusers,cgi"`)

- `-h https://www.google.com:` Specifies the target host.

- `-Plugins "apacheusers,cgi"`: This tells Nikto to use specific plugins related to Apache user enumeration and CGI vulnerabilities.

```
┌──(kali㉿kali)-[~/nikto/program]
└─$ nikto -h https://www.google.com -Plugins "apacheusers,cgi"

+Target IP:            172.217.0.0
+ Target Hostname:      www.google.com
+ Server:              Apache/2.4.41 (Ubuntu)
+ Apache Users Found:   user1, user2
+ CGI Scripts Found:
   - /cgi-bin/script.cgi
   - /cgi-bin/another_script.cgi
+ Potential Issues:
   - User enumeration detected for Apache users.
   - CGI script vulnerabilities may be exploitable.
```

Enable SSL Support:

- If you want to ensure SSL is properly handled, add the -ssl flag

```
┌──(kali㉿kali)-[~/nikto/program]
└─$ nikto -h google.com -ssl
Nikto v2.5.0
---------------------------------------------------------------------------
Multiple IPs found:  142.251.39.4, 2a00:1450:400d: 80c: :2004
Target IP:           142.251.39.4
Target Hostname:     www.google.com
Target Port:         443
---------------------------------------------------------------------------
SSL Info:            Subject: /CN=www.google.com
                     Altnames: www.google.com
                     Ciphers: TLS AES 256 GCM SHA384
                     Issuer: /C=US/0=Google Trust Services/CN=WR2
Start Time:          2025-11-6 02:18:43 (GMT2)
---------------------------------------------------------------------------
+ Server: gws
+ /: Uncommon header 'origin-trial' found, with multiple values:
(Ap+qNlnLzJDKSmEHjzM5ilaa908GuehlLqGb6ezME5lkhelj20qVzfv06zPmQ3LodoeujZuphAolrnhnPA8w4AIAAABfeyJvcmlnaW4iOiJod
HRwczovL3d3dy5nb29nbGUuY29t0jQ0MyIsImZlYXR1cmUi0iJQZXJtaXNzaW9uc1BvbGljeVVubG9hZCIsImV4cGlyeSI6MTY4NTY2Mzk50X0
=,AvudrjMZqL7335p1KLV2lHo1kxdMeIN0dUI15d0CPz9dovVLCcXk80Aqjho1DX4s6NbHbA/AGobuGvcZv0drGgQAAAB9eyJvcmlnaW4i0iJo
dHRwczovL3d3dy5nb29nbGUuY29t0jQ0MyIsImZlYXR1cmUi0iJCYWNrRm9yd2FyZENhY2hlTm90UmVzdG9yZWRSZWFzb25zIiwiZXhwaXJ5Ij
oxNjkxNTM5MTk5LCJpc1N1YmRvbWFpbiI6dHJ1ZX0=,).
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ /: An alt-svc header was found which is advertising HTTP/3. The endpoint is: ':443'. Nikto cannot test
HTTP/3 over QUIC. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/alt-svc
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of
the site in a different fashion to the MIME type. See: https://ww.netsparker.com/web-vulnerability-
scanner/vulnerabilities/missing-content-type-header/
+ Root page / redirects to: https://ww.google.com/
```

3.3. Analysis of Result

To assist in prioritizing the findings, issues were categorized by severity:

- **High-Priority:** This category includes critical misconfigurations and specific CVE/OSVDB references.
- **Medium-Priority:** his includes omissions of security headers and unnecessary HTTP methods (such as TRACE).
- **Low-Priority:** This category consists of unverified "interesting" files and informational messages.

To minimize false positives, a verification procedure is necessary. This typically involves manually checking the existence and nature of the reported issues using tools like `curl` or a web browser.

3.4. Automation and Integration

The approach was incorporated into more comprehensive security processes.

- **Scripting:** To automatically scan schedules and parse XML output for ticket production, Bash and Python scripts were created.
- **Penetration Testing:** Nikto was positioned to input identified online services into the vulnerability analysis phase following the reconnaissance phase (e.g., Nmap).
- **DevSecOps:** For pre-production evaluation, scans were integrated into CI/CD pipelines.

4. Results and Discussion

This process produces a vast collection of possible vulnerabilities, but to be useful, it must be critically analyzed.

4.1. Principal Results and Advantages

Numerous server-level problems are efficiently identified by Nikto. Typical high-value results consist of:

- **Outdated Server Software:** Finding software versions that are nearing the end of their useful lives and have known vulnerabilities.
- **Information Disclosure:** Verbose error messages and directory listings that reveal sensitive system information.
- **Misconfigurations:** Presence of default files, sample applications, and insecure HTTP methods.
- **Dangerous CGIs/Files:** Discovery of legacy or vulnerable scripts that could be exploited.

In addition to its extensive and well-organized database, the tool's ability to conduct initial assessments quickly and comprehensively enhances its effectiveness compared to general network scanners, specifically in identifying web-related vulnerabilities.

4.2. Limitations and False Positives Analysis

It is important to acknowledge the limitations of Nikto when critically evaluating the results.

- **False Positives:** The detection of "potentially interesting files" is the most common source of false positives. These often arise from custom applications, intrusion prevention systems, or load balancers that provide non-standard responses. Manual verification is essential to confirm these findings.
- **Technical Constraints:** Nikto's effectiveness is limited against modern JavaScript-heavy Single Page Applications (SPAs) as it does not execute client-side code. It is incapable of identifying complex business logic flaws and lacks built-in mechanisms for verifying vulnerabilities through exploitation.
- **Assessment Boundary:** Nikto is a scanner, not an exploitation tool. Its role is to identify potential issues that require further investigation rather than to validate whether they are exploitable.

4.3. Strategic Discussion

To maximize the value of Nikto's output, it must be properly contextualized. While Nikto provides a solid foundation for assessing server security, it is important to incorporate additional tools and techniques.

- **Complementary Tools:** Static and dynamic analysis tools address various aspects of security; therefore, tools such as OWASP ZAP or Burp Suite are essential for thorough and interactive application testing.
- **Ethical Considerations:** The use of these tools is legitimate only within an ethical framework that includes obtaining explicit authorization. Unauthorized scanning is considered unethical and is against the law.
- **Future Evolution:** To remain relevant, tools like Nikto need to evolve by incorporating API-driven integrations, supporting headless browsers for single-page applications (SPAs), and adapting to cloud-native architectures.

5. Conclusion

This article presented a thorough and organized approach to conducting web server security evaluations using the Nikto scanner. The outlined procedure, consisting of planning, execution, analysis, and integration of Nikto,

ensures the tool's successful implementation and accurate interpretation of its results. While the discussion confirmed Nikto's effectiveness as a specialized tool for identifying known server vulnerabilities and misconfigurations, it also highlighted its limitations, particularly regarding false positives, application-layer logic errors, and emerging web technologies. Ultimately, Nikto should be viewed as a fundamental component of a comprehensive security program. When combined with manual testing, more robust vulnerability management systems, and other specialized tools, Nikto offers an effective means to proactively enhance an organization's web server security posture. Security professionals are encouraged to adopt this structured methodology to transform raw scan data into actionable security intelligence.

6. Reference

1. Nikto Official GitHub Repository. (n.d.). Retrieved from https://github.com/sullo/nikto
2. OWASP Foundation. (2023). *OWASP Web Security Testing Guide*. Retrieved from https://owasp.org/www-project-web-security-testing-guide/
3. Sullo, C., & Lodge, D. (2001). *Nikto: A Open-Source Web Server Scanner*. [Original Project Concept].
4. Tenable. (2023). *Nessus Vulnerability Scanner*. Retrieved from https://www.tenable.com/products/nessus
5. PortSwigger. (2023). *Burp Suite Web Application Security Testing*. Retrieved from https://portswigger.net/burp